5

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad _____ Grup _____ Tarih _____

> **Kavram: SBOM** = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10).
> Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Alan	Değer
Bileşen	Component X (Safran ana kontrolcü / telemetri firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   1) Var mı? SBOM'da Component X ana kontrolcü ve telemetri modülü firmware'inde aranır → varsayım: **var**. **2) Sürüm etkileniyor mu?** CVE'nin etkilenen aralığında 2.4 var mı → üretici duyurusundan teyit; sürüm kapsamdaysa **evet**. **3) Ulaşılabilir mi?** Açık telemetri/uzak bakım veya servis portundan erişilebiliyorsa **evet**; yalnız yerel ve fiziksel erişim gerekiyorsa risk düşer. Üçü de evet ise **etkileniyoruz**; biri hayırsa öncelik düşer ama kayıt tutulur.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hayır. CVSS tek başına karar değildir; ulaşılabilirlik ve telafi edici önlem belirleyicidir. Makinenin temizlik işi sürer, ama **telemetri/uzak bakım bağlantısı hemen kapatılır** (varsayılan kapalı). Sömürü belirtisi (yetkisiz oturum, parametre değişimi) varsa makine hizmet dışı alınır ve Lab 6 akışı işler.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Önce test. Filoda aynı konfigürasyondaki **ayrı bir test/pilot makinede** (veya tezgâh simülasyonunda); yedek ve geri alma planı hazır, firmware imzası ve bütünlüğü doğrulanır. Test geçerse kademeli yayılım (pilot → filo).

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Etki analizi: sürüm notları ve SBOM bağımlılıkları → yama safety kontrolcü firmware'ine, ana kontrolcü–safety arayüzüne veya safety parametrelerine (hız limiti, koltuk/ölü adam zaman aşımı) dokunuyor mu? Dokunuyorsa **yeniden doğrulama** şart. Dokunmasa bile yama sonrası **fonksiyon testi**: acil stop, koltuk/ölü adam, park freni, hız limiti; sonuçlar kayda alınır.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   Telemetri/uzak bakım **varsayılan kapalı** veya yalnız jump server + VPN + MFA; yalnız giden bağlantı ve güvenlik duvarıyla portlar daraltılır; servis portu fiziksel kilit/USB kapatma; ilgili protokol filtrelenir; log izleme ve alarm; safety bağımsızlığı yeniden teyit edilir. Üreticiden yama takvimi istenir; **risk kabul kaydı** son tarihli tutulur.

☐ Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.

Cevaplar tipik bir binilebilir scrubber mimarisi varsayımıyla hazırlanmıştır; makinenin gerçek verileriyle doğrulayın.